

Authentication and session security policy

Document ID	DOC-009
Version	4.0
Date	2026-07-10
Status	current
Language	en

Policy requirements

DOC-009#SEC-01

MFA is mandatory for Workspace Admin, Security Admin, and Operator roles in production workspaces. SSO-managed members must satisfy the identity provider MFA claim when the workspace enforces federated authentication. Viewer and Analyst roles may be covered by workspace policy, but Enterprise regulated workspaces require MFA for every human account.

Sessions and reauthentication

DOC-009#SEC-02

Interactive sessions expire after 12 hours of inactivity and have a maximum lifetime of 7 days. Sensitive actions require reauthentication if the last strong authentication is older than 30 minutes. Changing password, resetting MFA, exporting unredacted payloads, and creating service credentials are sensitive actions.

Release 2.3 documentation described a 30-day maximum lifetime. That value is superseded by this policy as of 2026-07-10.

Recovery and emergency access

DOC-009#SEC-03

Users who lose an authenticator must follow the MFA recovery runbook. Help desk staff cannot disable MFA based only on an email request. Each Enterprise workspace must maintain two named break-glass accounts stored outside the normal SSO path. Their use creates a security event and requires review within one business day.

Service accounts

DOC-009#SEC-04

Service accounts cannot use interactive login. They authenticate through OAuth client credentials, must have scoped roles, and require secret rotation at least every 90 days. A service account may not hold Workspace Admin. Security Admin approval is required for scopes that export payload content.

Audience and prerequisites

DOC-009#SEC-05

This document is for people who operate or administer OrbeFlow and already understand workspaces, environments, and platform identifiers. It assumes authorized access to the cited records; investigation never grants broader access by itself. Its specific focus is identity control, explicit authorization, and traceability. Before acting, confirm production versus sandbox, active plan, region, and the revision or version shown by the evidence. The same display name may exist in several environments. A successful sandbox action must be reviewed again before production use. When a required role is unavailable, preserve evidence and route the case to the accountable owner instead of bypassing Access Gate controls.

Minimum evidence

DOC-009#SEC-06

Record UTC time, region, workspace, environment, relevant identifiers, and the observed result. For runs, combine event_id, RUN-, workflow_id, and revision. For tasks, include TSK- and state. For connections, include CON- and provider but never a secret. Copy codes such as PX-1047 or RL-4290 exactly. A screenshot may omit structured fields, so prefer a redacted export or machine-readable response. State when an identifier is missing rather than inventing it. Remove personal or commercial content that is not needed for diagnosis. The final record should allow another operator to reproduce the analysis without relying on the original investigator's memory.

Operational example

DOC-009#SEC-07

Consider a request about "Authentication and session security policy." The operator first bounds the time and environment, locates the object by stable identifier, and compares expected with observed behavior. If they differ, the operator records one hypothesis and selects the lowest-risk check. A description without an exact code may resemble several articles, so object type and current state are decisive. If evidence points to another domain, transfer the case with its timeline intact. Repeating an operation with a new identifier before understanding idempotency can create external duplicates, hide the first failure, or make later reconciliation ambiguous.

Boundaries and exceptions

DOC-009#SEC-08

This document does not authorize a plan change, weaker security control, record deletion, or access to unredacted content. Confirm commercial values and operational limits in the current catalog even when historical release notes contain numbers. An exception needs a reason, expiration, owner, and risk-appropriate approval. Authentication, retention, and residency exceptions require Security Admin participation. Emergency approval may accelerate incident mitigation but still requires later review. If two current sources appear inconsistent, stop the action and open a documentation correction instead of selecting the more convenient value.

Validation and related documents

DOC-009#SEC-09

Finish by confirming that the expected result occurred and that another module was not harmed. For changes, compare a before and after window. For support, reproduce only when safe. For policy questions, confirm

effective date and version. Useful related documents include DOC-005, DOC-010, DOC-011. A relationship supplies context, not automatic precedence. Current policy overrides an operational guide, the current catalog overrides historical release notes, and object evidence overrides assumptions based on display names. Record the section identifier used so later evaluation can distinguish the correct evidence from a passage that is merely semantically similar.